

IH&R Process Analysis

SecureNorth Incident SN-2026-0422-0917

Lab 02

Report title	IH&R Process Analysis: Secure North Incident SN-2026-0422-0917
Scenario	Secure North Inc. — Financial Services, Montréal, Québec
Due	April 26, 2026
Name	Mohammad Salem Hassani
Student ID	254880
Instructor	Asen Grozdanov

Executive Summary

On April 22, 2026 at 09:17 EST, SecureNorth Inc.'s SIEM platform triggered alert SN-2026-0422-0917 identifying repeated outbound connections from internal workstation 10.14.22.87 (Finance Department) to IP 185.220.101.34 — a known Tor exit node — following execution of a suspicious .exe file received via phishing email at 08:51. This report applies the SANS PICERL incident-response framework to the incident, compares it with the NIST SP 800-61 Rev. 2 lifecycle, and documents the full analytical process from framework reconnaissance through regulatory obligations.

Key findings:

- The SecureNorth alert meets the threshold of a confirmed P2 security incident: a phishing-delivered malware dropper with an active C2 beacon communicating over Tor constitutes a high-severity, partially contained compromise.
- Both NIST SP 800-61 Rev. 2 (4 phases, federal/policy focus) and SANS PICERL (6 phases, operational focus) are applicable; PICERL is the more actionable model for a live SOC response.
- Immediate containment should isolate workstation 10.14.22.87, acquire a forensic memory image with Volatility 3, and preserve chain-of-custody documentation before any eradication step.
- Three systemic weaknesses are identified: absence of email attachment sandboxing, no endpoint MFA policy, and an under-rehearsed IR playbook.
- As a financial-services firm in Québec, SecureNorth faces breach-notification obligations under both PIPEDA and Loi 25 (Law 25) if exfiltration of personal data is confirmed.

Main conclusion: SecureNorth must treat this alert as a confirmed incident, execute the PICERL playbook without delay, and mandate multi-factor authentication plus email sandboxing as the two highest-return controls for immediate deployment.

1.1 Framework Comparison Table

Comparison Axis	NIST SP 800-61 Rev. 2 (NIST, 2012)	SANS PICERL (2024 ed.)
Number of phases	4: Preparation; Detection & Analysis; Containment, Eradication & Recovery; Post-Incident Activity.	6: Preparation; Identification; Containment; Eradication; Recovery; Lessons Learned.
Originating body	National Institute of Standards and Technology (NIST), U.S. Dept. of Commerce. Published August 2012; superseded by Rev. 3 in April 2025.	SANS Institute — a private security-education and research organisation. The PICERL acronym is authoritatively documented in the SANS Incident Handler's Handbook.
Primary audience	U.S. federal agencies and regulated enterprises that require policy-grade, auditable incident response documentation aligned with FISMA.	SOC analysts, CSIRT practitioners, and IR responders who need operationally precise, phase-by-phase guidance during live incidents.
Strengths	Cyclical, non-prescriptive model; integrates with broader enterprise risk management; strong regulatory credibility; widely recognised internationally.	Granular phase separation (especially splitting containment, eradication, recovery) aids clear task ownership; direct tool-to-phase mapping; shorter learning curve.
Limitations	Combines three operationally distinct phases (containment, eradication, recovery) into one, which can obscure responsibilities under time pressure. Rev. 2 is now withdrawn and superseded.	Linear structure can create a false sense of sequence; less suited to complex multi-vector incidents where phases overlap; no regulatory standing on its own.
Typical use case	Formal IR programme design, audit preparation, board-level reporting, and regulatory alignment (HIPAA, FISMA, SOX).	Day-to-day SOC playbooks, tabletop exercises, junior analyst training, and live incident triage in financial and technology sectors.

Table 1. NIST SP 800-61 Rev. 2 vs. SANS PICERL — six-axis comparison. Sources: NIST [1]; SANS [2]; SentinelOne [3].

1.2 Real-World Framework Adoption

Two organisations have published IH&R policies grounded in these frameworks, demonstrating their real-world applicability beyond the academic context.

Canadian Centre for Cyber Security (CCCS).

The Government of Canada’s Canadian Centre for Cyber Security (CCCS) publishes its Incident Management Framework explicitly aligned to the NIST SP 800-61 lifecycle. The CCCS’s cyber incident management guidance organises response activities around the four NIST phases and mandates that federal departments adopt this structure for all Tier 1 and Tier 2 incidents [4]. What stands out as particularly mature is the CCCS’s requirement for a designated Cyber Event Management Team (CEMT) with pre-assigned escalation paths — a structural refinement that addresses the ambiguity in the base NIST model around authority and decision-making during a live incident.

Australian Signals Directorate (ASD) — Cyber Incident Response.

Australia’s ASD publishes its Cyber Incident Response Plan template structured around phases that closely mirror SANS PICERL: Preparation, Detection, Analysis, Containment, Eradication, Recovery, and Post-Incident Review [5]. The ASD’s template is notable for its mandatory “Indicators of Compromise (IOC) registry” — a live, centralised log of threat artefacts updated continuously during containment. This registry discipline, borrowed from the PICERL Identification phase, materially accelerates eradication by ensuring analysts share IOC context in real time rather than working in isolation.

1.3 Key Glossary Terms

The full 10-term glossary appears in *Appendix A*. Selected terms relevant to the framework section:

- SIEM (Security Information and Event Management) — a platform that aggregates log data from disparate sources, correlates events, and generates alerts based on defined rules. In this scenario, SecureNorth’s SIEM triggered alert SN-2026-0422-0917.
- SOAR (Security Orchestration, Automation, and Response) — software that automates repetitive SOC tasks such as alert enrichment, IOC lookups, and playbook execution, reducing analyst fatigue and mean-time-to-respond.
- IOC (Indicator of Compromise) — an observable artefact — such as an IP address, file hash, or domain name — that indicates a system may have been compromised.

Incident Timeline — Figure 1

Time (EST)	Phase	Description
08:51	Phishing email received	Finance Dept. workstation (10.14.22.87) receives email purporting to be vendor invoice with .exe attachment
08:51–08:55	.exe attachment executed	User opens attachment; malware dropper executes; C2 beacon initiated to 185.220.101.34 (Tor exit node)
08:55–09:17	C2 beaconing active	Repeated outbound port-443 connections over 22 minutes; SIEM logs accumulating; analyst unaware
09:17	SIEM alert fired	Alert SN-2026-0422-0917 triggered: P2 classification; SOC analyst notified
09:17–09:30	Identification	Analyst validates alert; checks threat intel on 185.220.101.34; escalates to IR Lead
09:30–09:45	Containment	Workstation isolated from network; memory image acquired; chain of custody initiated
09:45–11:00	Eradication	Malware dropper and C2 beacon removed; registry cleaned; system re-imaged from clean baseline
11:00–12:00	Recovery	Workstation restored; enhanced monitoring applied; user re-briefed on phishing awareness
T+72h	Lessons Learned / PIR	Post-Incident Review held; systemic weaknesses documented; controls updated

Figure 1. Incident timeline for SN-2026-0422-0917 — from initial phishing delivery to Post-Incident Review.
Own work, 2026-04-22. Phases coloured by PICERL stage.

Phase 1: Preparation

Before alert SN-2026-0422-0917 fired, a mature SecureNorth IR programme should have had the following controls in place: (1) a documented Incident Response Plan (IRP) with a pre-assigned CSIRT roster, escalation matrix, and defined severity-classification criteria; (2) an up-to-date asset inventory mapping all workstations — including 10.14.22.87 — to their owners, OS versions, and installed software; (3) email-gateway sandboxing to detonate suspicious attachments before delivery; (4) endpoint detection and response (EDR) tooling on all workstations with behavioural rules to flag .exe execution from email client processes; and (5) a tested communication plan defining when legal, compliance, and executive notification must occur. The absence of points 3 and 4 is precisely why this incident succeeded.

SOAR platform: TheHive (open-source).

TheHive is a scalable, open-source Security Orchestration, Automation, and Response (SOAR) platform maintained by StrangeBee [6]. In the SecureNorth context, TheHive would have ingested alert SN-2026-0422-0917 directly from the SIEM, automatically enriched the destination IP 185.220.101.34 via Cortex — its analysis engine — against AbuseIPDB and VirusTotal, and created a structured case with pre-populated tasks for each PICERL phase. This automation reduces mean-time-to-respond from the 13 minutes it took a human to notice the alert to under 60 seconds. TheHive also enforces chain-of-custody through timestamped, immutable case notes.

Phase 2: Identification

Incident classification: This event meets the threshold of a confirmed security incident at severity P2 (High).

The structured argument rests on three pillars. First, the triggering event is not an isolated anomaly: a .exe attachment was executed from a phishing email (initial access vector confirmed), and 22 minutes of continuous outbound connections to a known-malicious IP followed — this is not a false positive. Second, destination IP 185.220.101.34 is flagged by multiple open-source threat intelligence (OSINT) feeds as a Tor exit node, a common C2 relay for malware droppers and ransomware affiliates. Third, the Finance Department workstation processes accounts-payable data, meaning the confidentiality and integrity of sensitive financial records is at immediate risk. P1 (Critical) would apply only if active exfiltration or lateral movement were confirmed; P2 is appropriate pending forensic validation.

Additional data sources for enrichment:

- Endpoint logs (Windows Event Log, Sysmon): to identify the parent process that spawned the .exe, its command-line arguments, and any child processes (e.g., PowerShell, cmd.exe) indicative of a dropper executing a payload.
- DNS query history (internal resolver logs): to determine whether the workstation resolved any additional malicious domains, which would suggest multi-stage C2 or lateral movement preparation.
- Email gateway logs (spam filter, attachment sandbox): to retrieve the original email headers, sender domain reputation, and attachment hash for cross-referencing against VirusTotal.
- Proxy / firewall logs: to enumerate all external connections from 10.14.22.87 over the past 24 hours, detect data staging, and identify any lateral connections to internal hosts.

Threat intelligence enrichment: AbuseIPDB

To confirm the nature of 185.220.101.34, this analysis would query AbuseIPDB (<https://www.abuseipdb.com>) — a crowd-sourced database of reported malicious IPs [7]. AbuseIPDB provides a confidence score (0–100) based on community reports, the number of

distinct reporting sources, and the date of last activity. A score above 80 for this IP would corroborate the SIEM flag. VirusTotal’s IP analysis tab would additionally reveal whether any known malware families have used this IP as a C2 endpoint, providing attribution context for the IR report.

Severity	Label	Criteria	Assessment for SN-2026-0422-0917
P1	Critical	Active breach; data exfiltration in progress; production systems down	Not assigned — exfiltration unconfirmed at time of alert
P2	High	Confirmed compromise; contained but not eradicated; significant business impact	ASSIGNED — phishing + malware dropper + active C2 beacon confirmed; Finance Dept. data at risk
P3	Medium	Suspicious activity confirmed as malicious; limited scope	Would apply if .exe execution failed or C2 was blocked by firewall
P4	Low	Policy violation; minor anomaly; no confirmed malicious intent	Not applicable — evidence of active compromise

Table 2. Severity classification for incident SN-2026-0422-0917. Source: Cyber.SoHo Lab 02 classification scale [8].

Phase 3: Containment

Short-term containment — workstation 10.14.22.87:

- Network isolation (VLAN quarantine, not physical disconnection): The workstation is moved to an isolated network segment that blocks all external and internal routing but preserves the live network state for forensic capture. Physical cable pull would terminate the C2 session, destroying in-memory artefacts (encryption keys, process injection evidence) that Volatility 3 can recover from a live RAM image.
- Forensic memory acquisition: Before any system change, acquire a full RAM image using Volatility 3 or FTK Imager Lite. Hash the image (SHA-256) immediately and record the hash, analyst name, timestamp, and tool version in the chain-of-custody log. This preserves volatile evidence that would be lost on reboot.
- User account suspension: Temporarily disable the credentials of the affected user in Active Directory to prevent the attacker from pivoting to other systems using the compromised account, while avoiding a forced password reset that might alert the attacker.

Disconnect vs. monitor debate:

Immediate disconnection risks destroying volatile evidence (RAM contents, network-state tables, active C2 session details) that are critical for attribution and eradication. Controlled isolation — moving the workstation to a monitored quarantine VLAN — preserves this evidence while stopping lateral movement. However, if exfiltration is actively in progress and isolation is technically infeasible, disconnection is the correct choice: evidence integrity is secondary to stopping data loss.

Chain of custody (CoC) process:

From the moment containment begins, every action is logged in a dedicated CoC document: (1) timestamp (UTC); (2) analyst full name and employee ID; (3) action taken (e.g., “VLAN change executed by network team at 09:31 UTC”); (4) tool used and version; (5) hash values of any artefact collected. The CoC document is stored in a write-protected, access-controlled repository. No artefact changes hands without a signed transfer record. A broken CoC renders evidence inadmissible in any subsequent legal or regulatory proceeding.

Phase 4: Eradication

Assuming forensic analysis confirms a malware dropper and a C2 beacon on 10.14.22.87, eradication proceeds in the following sequence:

- Step 1 — IOC extraction and sharing: Extract all indicators from the memory image and logs (C2 IP, file hashes, registry keys, domain names) and push them to the SIEM and EDR platform as blocking rules. This prevents reinfection before the workstation is cleaned.
- Step 2 — Malware removal and registry cleaning: Using the EDR’s remediation capability (or Autoruns by Sysinternals), identify and delete the dropper binary, its persistence mechanism (registry run key, scheduled task, or WMI subscription), and any lateral-movement tools deposited during the incident.
- Step 3 — Credential rotation: Rotate all domain credentials associated with the compromised user and any service accounts the workstation had access to, preventing the attacker from reusing harvested tokens.
- Step 4 — Full system re-image: If the malware has achieved kernel-level persistence (rootkit behaviour detected in the Volatility memory analysis), re-image the workstation from a validated, clean baseline rather than attempting manual removal. Re-imaging is the only guarantee of completeness.

Eradication verification — Volatility 3 (open-source, Python 3):

Volatility 3, maintained by the Volatility Foundation, is the world’s most widely used open-source memory forensics framework [9]. To verify eradication is complete, a second memory image is acquired post-cleaning and analysed with Volatility’s “windows.pstree” plugin (to verify no hidden or unlinked processes remain), “windows.netstat” (to confirm no residual C2 connections), and “windows.cmdline” (to detect any command-line persistence). If all three

plugins return clean results, eradication is confirmed at the memory level. YARA rules derived from the malware's IOCs are then run against the disk image as a second verification layer.

Phase 5: Recovery

Before 10.14.22.87 is restored to production, the following validation steps must be completed:

- Clean baseline verification: Confirm the OS image used for re-imaging carries a valid cryptographic hash matching the organisation's approved baseline repository.
- Patch and configuration check: Apply all outstanding OS and application patches before reconnection. Confirm security settings (macro execution disabled, EDR agent active, local firewall rules in place).
- Credential integrity confirmation: Verify that all rotated credentials are propagated and that no old tokens persist in cached credential stores (e.g., Windows Credential Manager).
- EDR and SIEM rule validation: Confirm that the IOC blocking rules pushed during eradication are active and that the EDR agent is reporting normally from the restored workstation.
- User re-briefing and phishing simulation: Before returning the device to the user, conduct a 15-minute phishing-awareness session and run a simulated phishing test to assess susceptibility.

Post-recovery monitoring (30 days):

- Hourly SIEM review of all outbound connections from the Finance Department subnet, with specific watchlists for Tor-related IP ranges and known C2 domains.
- Daily EDR behavioural alert review for the restored workstation, focusing on anomalous process execution chains (e.g., Office spawning PowerShell).
- Weekly review of DNS query logs for the Finance subnet to detect domain-generation algorithm (DGA) activity that may indicate a dormant secondary implant.

Phase 6: Lessons Learned — Post-Incident Review (PIR)

PIR Meeting Agenda — Incident SN-2026-0422-0917

#	Agenda Item	Duration	Owner
1	Incident timeline walkthrough — factual reconstruction of events from 08:51 to resolution	15 min	IR Lead
2	Root cause analysis — why the phishing email bypassed controls and why the .exe executed successfully	20 min	Forensic Analyst

#	Agenda Item	Duration	Owner
3	Detection gap review — why 22 minutes elapsed between .exe execution and SIEM alert	15 min	SOC Manager
4	Systemic weaknesses — structured discussion of three identified control gaps (see below)	20 min	CISO
5	Regulatory obligations review — PIPEDA / Loi 25 notification assessment and status	10 min	Legal / Compliance
6	Remediation action plan — owners, deadlines, and success metrics for each corrective action	15 min	IR Lead
7	Framework and playbook updates — revisions to IR playbooks, SIEM rules, and escalation matrix	10 min	All
8	Closing and next PIR scheduling	5 min	IR Lead

Table 3. PIR meeting agenda for incident SN-2026-0422-0917. Total duration: 110 minutes.

Three systemic weaknesses and remediation:

- Weakness 1 — No email attachment sandboxing. The .exe attachment reached the user's inbox and executed without any detonation analysis. Remediation: Deploy an email sandboxing solution (e.g., Proofpoint TAP or the open-source Cuckoo Sandbox integrated with the mail gateway) within 30 days. Configure the gateway to quarantine all .exe, .bat, and macro-enabled Office files pending sandbox analysis.
- Weakness 2 — Absence of EDR behavioural rules. No alert fired when a mail client (Outlook) spawned a .exe child process — a classic dropper behaviour. Remediation: Within 14 days, deploy EDR parent-process rules that block or alert on any mail client or browser spawning executable processes. This is a one-hour configuration task on any modern EDR platform.
- Weakness 3 — Untested IR playbook. The 22-minute gap between malware execution and analyst awareness reveals that no automated playbook was triggered. Remediation: Within 60 days, implement TheHive-based automated case creation for all P2+ SIEM alerts, with auto-enrichment and paged notification to the on-call analyst within 2 minutes of alert generation.

Regulatory Notification Obligations (Québec, Financial Services)

SecureNorth Inc., as a financial-services firm operating in Montréal, Québec, faces obligations under two primary frameworks if the incident results in confirmed personal-data exfiltration:

- PIPEDA (Personal Information Protection and Electronic Documents Act): Canada’s federal private-sector privacy law requires organisations to notify the Office of the Privacy Commissioner of Canada (OPC) and affected individuals of any breach that poses a “real risk of significant harm” (RROSH) to individuals [10]. Notification must occur “as soon as feasible” after the RROSH determination. SecureNorth must also maintain a breach register of all incidents, regardless of RROSH threshold.
- Loi 25 (Québec Law 25 / Act to modernize legislative provisions respecting the protection of personal information): Fully in force as of September 2023, Loi 25 requires notification to the Commission d’accès à l’information (CAI) and affected individuals “as soon as possible” when a confidentiality incident poses a “risk of serious injury” [11]. Fines for non-compliance reach up to CAD 25 million or 4% of worldwide turnover. SecureNorth must designate a Privacy Officer and maintain a confidentiality incident register.

Both regimes require parallel notification tracks: regulatory body first, individuals second. SecureNorth’s legal and compliance officer must initiate the RROSH / risk-of-serious-injury assessment immediately upon confirmation of exfiltration to avoid missing statutory notification windows.

Appendix A — Glossary of Key Terms

#	Abbreviation (Full Term)	Definition & Source
1	SIEM — Security Information and Event Management	A platform that aggregates, correlates, and analyses log data from across an IT environment to detect threats and generate alerts. In this scenario, SecureNorth’s SIEM triggered alert SN-2026-0422-0917. Source: NIST SP 800-61 Rev. 2 [1].
2	SOAR — Security Orchestration, Automation, and Response	Software that automates repetitive SOC workflows — such as alert enrichment, IOC lookups, and playbook execution — reducing analyst workload and accelerating response. Example: TheHive. Source: [6].
3	IOC — Indicator of Compromise	An observable artefact — such as an IP address, file hash, or domain name — that indicates a system may have been compromised. IOCs are shared among IR teams to accelerate detection and containment. Source: NIST SP 800-61 Rev. 2 [1].
4	CSIRT — Computer Security Incident Response Team	A dedicated team, either internal or retained externally, activated during a confirmed security incident to coordinate investigation, containment, and remediation. Source: NIST SP 800-61 Rev. 2 [1].
5	C2 — Command-and-Control	A server or channel used by an attacker to remotely direct malware on a compromised host. In this incident, 185.220.101.34 (a Tor exit node) served as the C2 relay. Source: MITRE ATT&CK T1571 [12].
6	CoC — Chain of Custody	The documented, unbroken record of who collected, handled, and analysed a piece of digital evidence, and when. A broken CoC can render evidence inadmissible in legal proceedings. Source: Cyber.SoHo Lab 02 [8].
7	PIPEDA — Personal Information Protection and Electronic Documents Act	Canada’s federal private-sector privacy law, requiring breach notification to the OPC and individuals when a “real risk of significant harm” exists. Source: Office of the Privacy Commissioner of Canada [10].
8	PIR — Post-Incident Review	A structured meeting conducted after an incident is resolved to analyse root causes, identify systemic weaknesses, and update defences. Equivalent to the “Lessons Learned” phase in PICERL. Source: SANS [2].
9	EDR — Endpoint Detection and Response	A security solution installed on endpoints that continuously monitors for malicious behaviour, records activity for forensic replay, and enables remote containment actions such as process termination or network isolation. Source: SentinelOne [3].
10	Tor — The Onion Router	A privacy-enhancing network that routes traffic through multiple encrypted relays, masking the true destination. Attackers use Tor exit

#	Abbreviation (Full Term)	Definition & Source
		nodes as C2 relays to evade IP-based blocking. Destination IP 185.220.101.34 is a known Tor exit node. Source: Tor Project [13].

Appendix B — References

-
- [1] [1] NIST. Computer Security Incident Handling Guide (SP 800-61 Rev. 2). August 2012 [withdrawn April 2025; used as specified by this exercise].
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>. Accessed 2026-04-22.
- [2] [2] SANS Institute. Incident Handler’s Handbook. 2024 edition. <https://www.sans.org/white-papers/33901/>. Accessed 2026-04-22.
- [3] [3] SentinelOne. SANS 6-Step Incident Response Framework Guide. 2025.
<https://www.sentinelone.com/cybersecurity-101/cybersecurity/sans-incident-response/>. Accessed 2026-04-22.
- [4] [4] Canadian Centre for Cyber Security (CCCS). Cyber Incident Management Framework. Government of Canada. <https://www.cyber.gc.ca/en/guidance/cyber-incident-management-framework>. Accessed 2026-04-22.
- [5] [5] Australian Signals Directorate (ASD). Cyber Incident Response Plan. Australian Government.
<https://www.cyber.gov.au/resources-business-and-government/governance-and-user-education/incident-response/cyber-incident-response-plan>. Accessed 2026-04-22.
- [6] [6] StrangeBee / TheHive Project. TheHive — Scalable, Open Source and Free Security Incident Response Platform. <https://thehive-project.org/>. Accessed 2026-04-22.
- [7] [7] AbuseIPDB. IP Abuse Reports. <https://www.abuseipdb.com/>. Accessed 2026-04-22.
- [8] [8] Cyber.SoHo Educational Hub. Research Exercise 02 — The Incident Handling & Response (IH&R) Process. April 2026.
- [9] [9] Volatility Foundation. Volatility 3 — Memory Forensics Framework.
<https://volatilityfoundation.org/>. Accessed 2026-04-22.
- [10] [10] Office of the Privacy Commissioner of Canada. PIPEDA Breach of Security Safeguards Regulations. https://www.priv.gc.ca/en/privacy-topics/privacy-laws-in-canada/the-personal-information-protection-and-electronic-documents-act-pipeda/pipeda-compliance-help/pipeda-interpretation-bulletins/security_safeguards/. Accessed 2026-04-22.
- [11] [11] Commission d’accès à l’information (CAI). Québec Law 25 — Act to Modernize Legislative Provisions Respecting the Protection of Personal Information.
<https://www.cai.gouv.qc.ca/en/>. Accessed 2026-04-22.
- [12] [12] MITRE ATT&CK. T1571: Non-Standard Port. <https://attack.mitre.org/techniques/T1571/>. Accessed 2026-04-22.
- [13] [13] The Tor Project. Tor Overview. <https://www.torproject.org/about/overview/>. Accessed 2026-04-22.
- [14] [14] CISA. Cybersecurity Incident Response Resources.
<https://www.cisa.gov/topics/cybersecurity-best-practices/organizations-and-cyber-safety/cybersecurity-incident-response>. Accessed 2026-04-22.
- [15] [15] BigID. Québec Law 25: What Canada’s New Privacy Law Requires.
<https://bigid.com/blog/quebec-law-25-canada-new-privacy-law-requirements/>. Accessed 2026-04-22.